CASE STUDY

The Ivanti Connect Secure Zero-Day Chain of October 2026 (CVE-2026-104935, CVE-2026-111357, CVE-2026-118527): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people on the hook here were the teams who run Ivanti Connect Secure (ICS), the remote-access VPN appliance that Shadowserver counted on more than 5,000 internet-facing hosts [19] [20] (**Reported**). In October 2026 they were asked to patch the same appliance twice in just over two weeks, and told that a clean integrity check might not mean a clean box [10] [12] (**Confirmed**).

Volexity found the chain on a customer appliance fully patched at 22.8R2.4; exploitation of that appliance began on 3 October 2026 [12] (**Confirmed**). Ivanti disclosed CVE-2026-104935 on 13 October as under limited exploitation [1] (**Confirmed**). CVE-2026-111357, the root escalation that completed the chain, was published by the MITRE CNA on 15 October, and its record describes exploitation in the wild in October 2026; CISA's SSVC enrichment marked exploitation active the same day [4] [7] (**Confirmed**). Ivanti's fix for it did not ship until 29 October [12], and CISA's Known Exploited Vulnerabilities (KEV) catalog gave two of the three CVEs a three-day deadline with forensic triage [9] (**Confirmed**).

Key facts at a glance

Field	Value
Product	Ivanti Connect Secure (ICS), branches 22.8, 25.1.1 and 25.1.2 [3] [10] [15]
CVEs	CVE-2026-104935, CVE-2026-111357, CVE-2026-118527; classes and scores in Part 2 [3] [4] [5]
First exploitation	3 Oct 2026 per Volexity [12]; 1 Oct per Defused as quoted in the press [19] [21] (**Reported**)
Disclosure and fixes	13 Oct: 25.1.1.2, 25.1.3.0/25.1.3.1, 22.8R2.5 [1] [18]; 29 Oct: 25.1.1.3 and 22.8R2.6 [5] [12] [22]
KEV	CVE-2026-104935 added 13 Oct, due 16 Oct; CVE-2026-111357 and CVE-2026-118527 added 30 Oct, due 2 Nov and 13 Nov [9]
Actor	UTA0576, a previously unknown group tracked by Volexity; low-confidence criminal motive; medium-confidence use of large language models [12]
Victims	One appliance described; no sector, geography or count published [12]

Key findings

- **The October 13 builds did not close the chain.** INCIBE-CERT states that 25.1.1.2 and 22.8R2.5 do not fix the two later CVEs [15] (**Confirmed**). For 16 days after public disclosure on 13 October, the privilege escalation was exploited and unpatched [12] (**Confirmed**).
- **There was no implant to find.** UTA0576 planted no web shell or backdoor, and Ivanti's Integrity Checker Tool missed the in-memory library patching [10] [12] (**Confirmed**).
- **The appliance was a doorway to the directory.** The actor took LDAP, LAPS and BitLocker secrets, sniffed credentials and sprayed passwords, which Volexity assesses with high confidence as preparation for lateral movement [12] (**Confirmed**).
- **The record disagrees with itself.** Version cutoffs, the CWE and the CVSS score differ across sources, and CVE-2026-118527 was KEV-listed on 30 October, four days before its CVE record was published on 3 November [3] [4] [5] [7] [9] [10] [23] (**Confirmed**).
- **This is not the 2024 Ivanti story again.** Unlike the China-nexus Cutting Edge campaign, which used web shells and custom malware, UTA0576 left no implant, and Volexity assesses, with low confidence, a criminal rather than espionage motive [12] [24] (**Inferred** comparison).

Top recommendations

1. Run 25.1.1.3, 25.1.3.1 or 22.8R2.6 or later, and plan the move off 22.8 before 31 Jan 2027 [10] [15] (**Confirmed** as INCIBE-CERT's and CISA's guidance).
2. Treat any appliance on an affected build that was internet-exposed from 1 October 2026 until it reached 25.1.1.3, 25.1.3.1 or 22.8R2.6 as possibly compromised (**Inferred** from [12] [19]), and do not accept an Integrity Checker pass as proof of a clean device; use memory and network forensics [10] [12] (**Confirmed** as CISA's and Volexity's guidance).
3. Recover by CISA's sequence: factory reset and upgrade, then reset every password, certificate and API key [10] (**Confirmed** as CISA's guidance).

4. Rotate the directory secrets the appliance could reach: LDAP bind, LAPS and BitLocker (**Inferred** from what Volexity saw taken [12]).
5. Watch for large numbers of requests to the welcome.cgi endpoint, and for mismatches between the request path and the routing header Volexity names; alert on authentication failures from the appliance's internal interface [12] [21] (**Confirmed** as Volexity's guidance; the internal-interface point is **Reported**).

Scope and method

This brief covers the three Connect Secure CVEs from the first observed exploitation through the KEV catalog of 10 November 2026. It does not repeat the October roundup in PHP2Shell and October 2026 or the China-nexus Ivanti campaigns of 2024 and 2025 in Threat Actors: China [25]. The Year 2026 in Intrusions places this chain among the year's other edge-device events in one paragraph and links here as the home study. Tradecraft is described at advisory level: no request formats, paths beyond the endpoint Volexity names for detection, or exploit steps. All times are UTC.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Ivanti's own posts, the CVE and NVD records, the CISA KEV catalog and alert, Volexity's report, and national CERT advisories
Reported	Known through journalism or a secondary relay of a primary, including Rapid7's relay of Ivanti's version table
Demonstrated	Shown by this study's own check of data (the library's ATT&CK, CWE, CAPEC and D3FEND files)
Inferred	This study's own reasoning from cited facts, labelled where it appears

Ivanti's own advisory could not be opened, so its content is known through CISA, the CVE records, NVD, the national CERTs and Rapid7.

Part 1: what happened

Date (2026)	Event	Sources	Grade
July	A portion of the CVE-2026-104935 flaw is patched in the 25.1.3.0 release	[18]	Reported
30 Sep to 7 Oct	An attacker virtual private server runs an OpenVPN server	[12]	Confirmed
1 Oct	Defused says it first saw the activity on public honeypots and in customer instances	[19] [21]	Reported
3 Oct	Exploitation of the victim appliance, ICS 22.8R2.4 (Build 19097), begins	[12]	Confirmed
5 to 10 Oct	Volexity investigates at a Network Security Monitoring customer and shares indicators with its customers on 10 Oct	[12]	Confirmed
13 Oct, 14:33 to 16:17	Ivanti discloses a Connect Secure flaw under limited exploitation; CVE-2026-104935 published by Ivanti as CNA, then by NVD	[1] [3] [6]	Confirmed
13 Oct	KEV adds CVE-2026-104935, due 16 Oct; CISA alert issued; Volexity report and Canada's AV26-1035 published; Rapid7 urges emergency patching	[9] [10] [12] [14] [18]	Confirmed (Rapid7 Reported)
14 Oct	INCIBE-CERT publishes INCIBE-2026-737	[15]	Confirmed
15 Oct	The MITRE CNA publishes CVE-2026-111357, whose record describes exploitation in the wild in October 2026; CISA's SSVC enrichment marks exploitation active the same day. No vendor fix exists yet	[4] [7]	Confirmed
20 Oct	Singapore's CSA issues AL-2026-147	[17]	Confirmed
29 Oct	Ivanti ships 25.1.1.3 and 22.8R2.6, fixing CVE-2026-111357 and CVE-2026-118527, and updates its advisory	[5] [12] [20] [22]	Confirmed (advisory update day Reported)
30 Oct	KEV adds CVE-2026-111357 (due 2 Nov) and CVE-2026-118527 (due 13 Nov); CISA revises its alert; Canada issues Update 2	[9] [10] [14]	Confirmed
2 Nov	HKCERT bulletin rates the risk High	[16]	Confirmed
3 Nov	CVE-2026-118527 record published; INCIBE-CERT updates its advisory	[5] [8] [15]	Confirmed
10 Nov	Ivanti's November Security Update does not mention Connect Secure	[2]	Confirmed

Discrepancies in the record

- **Affected versions.** CISA's revised alert lists 25.1.1.2 and prior, 25.1.2.2 and prior, and 22.8R2.5 and prior; the CVE-2026-104935 record lists 22.8R2.5 as unaffected; the CVE-2026-111357 record lists only 22.8R2.4; NVD's CPEs run to before 25.1.1.3 [3] [4] [7] [10] (**Confirmed**). Read together, the 13 October builds closed the bypass and code execution but not the full chain (**Inferred**).

- **Which weakness.** The CVE-2026-111357 record and NVD give CWE-829; the KEV entry gives CWE-306, CWE-862 and CWE-345 and names it "Missing Authentication for Critical Function" [4] [7] [9] (**Confirmed**).
- **Which score.** MITRE's CVSS for CVE-2026-111357 is 7.0; the press cites 8.8 [7] [23] (**Confirmed** for 7.0; 8.8 **Reported**).
- **KEV before CVE.** CVE-2026-118527 was added to KEV on 30 October, four days before its CVE record was published [5] [9] (**Confirmed**).
- **Start date.** Volexity gives 3 October; the 1 October date rests on Defused telemetry that was not opened [12] [19] [21] (**Reported** for 1 October).

Part 2: the technical record

CVE	CNA, published	Weakness and class	CVSS 3.1	Fixed in	CISA SSVC
CVE-2026-104935	Ivanti, 13 Oct	CWE-290, authentication bypass by spoofing; remote unauthenticated command execution	8.6, AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L	25.1.1.2, 25.1.3.0, 25.1.3.1, 22.8R2.5; 22.7R2.14 and prior not impacted	Active, automatable, total [3] [6]
CVE-2026-111357	MITRE, 15 Oct	CWE-829; privilege escalation to root via the dsinvoked broker trusting DSCache configuration data	7.0, AV:L/AC:H/PR:L	25.1.1.3, 22.8R2.6	Active, not automatable, total [4] [7]
CVE-2026-118527	Ivanti, 3 Nov	CWE-340, predictable filenames; authenticated upload of attacker-controlled content to a known location	4.3	25.1.1.3, 22.8R2.6	Active, not automatable, partial [5] [8]

Sources: the CVE records and NVD [3] to [8], fixed versions for CVE-2026-104935 as Rapid7 relays Ivanti's table [18] (**Reported**) and for the later two from the CVE-2026-118527 record and INCIBE-CERT [5] [15] (**Confirmed**).

The chain, at advisory level. Volexity describes three links [12] (**Confirmed**):

1. A request-routing authentication bypass that reaches protected CGI handlers.
2. A file write in an upload handler, combined with a race condition, that yields code execution. Ivanti tracks the bypass and the code execution together as CVE-2026-104935.
3. Privilege escalation to root through the dsinvoked broker trusting DSCache configuration data, now CVE-2026-111357.

The upload handler's predictable-path element matches the CVE-2026-118527 description, but Volexity's post never names that CVE; the mapping is ours (**Inferred**). CISA's KEV entries for both later CVEs say each can be chained with the other two [9] (**Confirmed**).

What the actor did on the box. With root, UTA0576 extracted stored LDAP credentials, ran LDAP queries for LAPS passwords and BitLocker recovery keys, used a custom tool able to Kerberoast (Volexity notes the Kerberoast function was not used), sprayed passwords, ran a renamed packet-capture tool that harvested LDAP and HTTP Basic credentials and NTLM hashes, and reviewed logs for valid usernames [12] (**Confirmed**). Volexity describes no lateral movement: the operation was detected and disrupted before the actor's objectives could be determined, and Volexity assesses with high confidence that the activity was preparation for lateral movement [12] (**Confirmed**).

Why it was hard to see. Commands, results and data moved through the exploit chain's own HTTPS requests and responses, with no separate command channel [12] (**Confirmed**). The actor patched library code only in memory, restored configuration afterward, and tampered with the Ivanti debug log and the Linux audit log; Volexity rebuilt the chain and found the sniffer through memory and core-dump analysis [12] (**Confirmed**). Rapid7 said at disclosure that reliable indicators were not yet available [18] (**Reported**); Volexity later published one exploitation IP and YARA rules [13] (**Confirmed**).

Part 3: who and why

Volexity tracks the actor as UTA0576, a previously unknown group. It assesses with low confidence that the motive is criminal rather than espionage, and with medium confidence that the actor uses large language models for exploit development and post-exploitation work [12] (**Confirmed** as Volexity's assessment). None of the government advisories opened for this study names an actor; the CISA alert names no actor, victim or agency [10] [14] [15] [16] [17] (**Confirmed**).

The only earlier activity Volexity relates this to is UTA0533's similar reading of packet captures on SonicWall SMA; it does not mention UTA0178 or UNC5221 [12] (**Confirmed**). ATT&CK has no group object for UTA0576 [24] (**Demonstrated**).

The library's Cutting Edge campaign page records the December 2023 to February 2024 ICS zero-day campaign by suspected China-nexus UNC5221/UTA0178 and UNC5325, with web shells and custom malware [24] (**Confirmed**), and Threat Actors: China covers UNC5221's exploitation of CVE-2025-0282 from mid-December 2024 [25] (**Confirmed**). With no implant and only a low-confidence criminal assessment, the 2026 chain should not be attached to UNC5221 on the strength of the product alone (**Inferred**). Volexity's LLM assessment concerns how the actor built and ran its tooling, not an autonomous attack [12] (**Inferred** from Volexity's wording).

Part 4: impact and response

Victims. Volexity describes one compromised appliance, gives no victim count, sector or geography, and says the operation was detected and disrupted, so the actor's ultimate objectives could not be determined [12] (**Confirmed**). Ivanti said at disclosure it was working directly with affected organizations [1] (**Confirmed**). Shadowserver's counts of over 5,500 exposed instances at disclosure and over 5,000 in early November come via BleepingComputer [19] [20] (**Reported**; the dashboard was not opened).

The vendor. Ivanti's 13 October post told customers to upgrade immediately and run the Integrity Checker Tool [1] (**Confirmed**). Ivanti later said the CVE-2026-104935 fix was already in QA when exploitation was found and that it chose not to delay it once the privilege escalation was discovered [20] [23] (**Reported**). It said limited indicators of compromise were available when it shipped the 29 October builds [22] (**Reported**).

CISA and KEV. All three KEV entries cite Binding Operational Directive (BOD) 26-04 and CISA's Forensics Triage Requirements [9] (**Confirmed**). BOD 26-04, issued 10 June 2026, requires federal civilian agencies to remediate or mitigate within three days where a KEV timeline includes forensic triage, and to assess whether the asset is compromised [11] (**Confirmed**). The two forensic-triage entries got exactly three days; CVE-2026-118527, without forensic triage, got 14 [9] (**Inferred** from the dates). KEV marks known ransomware use as Unknown for all three [9] (**Confirmed**).

KEV context (catalog 2026.11.10)	Value
Ivanti entries	38, of which 12 flagged Known ransomware use
Connect Secure and Pulse Connect Secure entries	17 since 3 Nov 2021 (16 under vendor Ivanti, 1 under Pulse Secure), including the 2026 three
Earlier ICS entries (2024 and 2025) flagged Known	CVE-2023-46805, CVE-2024-21887, CVE-2024-21893, CVE-2025-0282, CVE-2025-22457
The 2026 three	Unknown

Source: computed from the KEV catalog [9] (**Confirmed**).

National CERTs. Canada's AV26-1035 (Update 2, 30 October) lists ICS prior to 25.1.1.3, 25.1.3.1 and 22.8R2.6 [14]; INCIBE-CERT says all three are exploited [15]; HKCERT (2 November) reports the two later CVEs exploited in the wild [16]; and Singapore's CSA (20 October) urged immediate updates for CVE-2026-104935 [17] (**Confirmed**).

Part 5: the defender and vulnerability-management view

A scanner that read version strings on 14 October would have marked a 22.8R2.5 appliance as fixed while the root escalation was still open (**Inferred** from [4] [15]). The patch level that closes the known chain is 25.1.1.3, 25.1.3.1 or 22.8R2.6 [14] [15] (**Confirmed**).

Control	Where it meets the record
Patch to the full-chain builds, then leave 22.8	25.1.1.2 and 22.8R2.5 do not fix the later CVEs [15]; 22.8 end of life 31 Jan 2027 [10]
Use memory and network forensics, not an integrity check alone	In-memory patching defeated the Integrity Checker Tool; memory forensics found the chain and the sniffer [10] [12]
Monitor for large numbers of welcome.cgi requests, and separately for request-path and routing-header mismatches	Volexity's two detection items [12]
Alert on auth failures from the appliance's internal interface	Volexity's Sean Koessel, as quoted [21] (**Reported**)
Factory reset, then rotate every credential and certificate	CISA's recovery sequence [10]
Rotate directory secrets the appliance could read	LDAP bind, LAPS and BitLocker (**Inferred** from [12])

Control	Where it meets the record
Use SSVC and KEV forensic-triage flags to order work	SSVC marked CVE-2026-104935 automatable with total impact [6]; KEV forensic triage drove three-day deadlines [9] [11]

What is overstated and what is understated

- **Overstated:** read alone, the CISA alert's grouping can suggest all three CVEs are internet entry points, but only CVE-2026-104935 is remote and unauthenticated on its record; CVE-2026-111357 is local and CVE-2026-118527 needs authentication [3] [4] [5] [10] (**Inferred**). The 1 October start date rests on unopened telemetry [21] (**Reported**). Any reading of this chain as AI-built goes further than Volexity's medium-confidence assessment that the actor used LLMs [12] (**Inferred**).
- **Understated:** the chain was first seen on a fully patched appliance [12]; the privilege escalation stayed unpatched for 16 days after disclosure while exploited [12]; the 13 October builds did not close the chain [15]; and an Integrity Checker pass was a false clean [12] (**Confirmed**). The victim count is not known, and one described appliance is a floor, not a total (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files [24] (**Demonstrated**). Revoked ids were resolved through `data/attack/superseded_by.jsonl` [24] (**Demonstrated**). No source names ATT&CK ids for this activity, so every id below is this study's mapping of a described behavior (**Inferred**). No industrial system is involved, so no ATT&CK for ICS techniques apply.

Groups, software and campaigns

ATT&CK has no group object for UTA0576 and no software object for its tooling [24] (**Demonstrated**), so none is bound. One object is related, not bound:

Object	ATT&CK id	Relationship to this record
Cutting Edge	C0029	The December 2023 to February 2024 ICS zero-day campaign by suspected China-nexus actors [24]. Lineage only; Volexity ties UTA0576 to no earlier Ivanti actor [12]

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1587.004	Exploits	Resource Development	Zero-day chain used by UTA0576; Volexity assesses with medium confidence that LLMs were used for exploit development (13 Oct)	[12]
T1588.007	Artificial Intelligence	Resource Development	Medium-confidence use of LLMs for exploit development and post-exploitation (Volexity, 13 Oct)	[12]
T1190	Exploit Public-Facing Application	Initial Access	Auth bypass and code execution against the appliance from 3 Oct	[3] [12]
T1059.004	Unix Shell	Execution	The uploaded Perl script runs a Bash script, which runs the next stage (Volexity, 13 Oct)	[12]
T1059.006	Python	Execution	An in-memory Python script, run by the Bash stage, carries the privilege escalation exploit (Volexity, 13 Oct)	[12]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	Root via dsinvoked and DSCache, CVE-2026-111357 (15 Oct record)	[4] [12]
T1601.001	Patch System Image	Defense Impairment	Library code patched only in memory during exploitation and then restored, which the Integrity Checker could not see (Volexity, 13 Oct)	[12]
T1070	Indicator Removal	Stealth	Ivanti debug log tampered with (Volexity, 13 Oct)	[12]
T1685.006	Clear Linux or Mac System Logs	Defense Impairment	Recent entries selectively removed from the Linux audit log (Volexity, 13 Oct)	[12]
T1036.003	Rename Legitimate Utilities	Stealth	Renamed packet-capture tool (Volexity, 13 Oct)	[12]
T1140	Deobfuscate/Decode Files or Information	Stealth	The Python stage is delivered Base64-encoded and zlib-compressed, then decoded on the appliance (Volexity, 13 Oct)	[12]
T1070.004	File Deletion	Stealth	The LDAP and Kerberos helper scripts deleted after use, and the root-stage payload unlinks its own file (Volexity, 13 Oct)	[12]
T1564.001	Hidden Files and Directories	Stealth	The renamed packet-capture tool and its capture files kept in a hidden dot-directory, out of normal file listings (Volexity, 13 Oct)	[12]
T1552	Unsecured Credentials	Credential Access	Stored LDAP credentials extracted; LDAP queries for LAPS passwords and BitLocker recovery keys (Volexity, 13 Oct)	[12]
T1040	Network Sniffing	Credential Access, Discovery	LDAP and HTTP Basic credentials and NTLM hashes harvested from traffic (Volexity, 13 Oct)	[12]
T1110.003	Password Spraying	Credential Access	Spraying against directory accounts (Volexity, 13 Oct)	[12]
T1654	Log Enumeration	Discovery	Logs reviewed for valid usernames (Volexity, 13 Oct)	[12]
T1087.002	Domain Account	Discovery	Active Directory queried through a compromised service account and the results exported (Volexity, 13 Oct)	[12]

ID	Name	Tactic(s)	Dated event or report	Sources
T1016	System Network Configuration Discovery	Discovery	The appliance's DNS resolver configuration exfiltrated and internal domains of the victim resolved (Volexity, 13 Oct)	[12]
T1005	Data from Local System	Collection	Appliance configuration and authentication data, including authentication methods, collected for exfiltration (Volexity, 13 Oct)	[12]
T1071.001	Web Protocols	Command and Control	Commands and results carried in the exploit's HTTPS requests (Volexity, 13 Oct)	[12]
T1041	Exfiltration Over C2 Channel	Exfiltration	Data returned in exploit responses, no separate channel (Volexity, 13 Oct); CISA cites data exfiltration (30 Oct)	[10] [12]

Fit notes (**Inferred**): T1601.001 is written for network-device operating systems and covers in-memory changes at runtime; the ICS appliance is such a device, so the fit is close but not exact. T1552 is bound at the parent level because the sources do not say where the stored LDAP credentials lived. No technique is bound for the upload-handler file write; it is part of the T1190 exploitation. No technique is bound for Kerberoasting: Volexity says the tool's Kerberoast function was not used [12]. ATT&CK has no Perl sub-technique, so the Perl stage is carried by T1190 and the Unix Shell and Python rows. T1087.002 and T1016 are the discovery behaviors Volexity describes; the packet captures and log review that served the same end are bound above as T1040 and T1654.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-290	Authentication Bypass by Spoofing	CVE-2026-104935 record, NVD and KEV	[3] [6] [9]
CWE-829	Inclusion of Functionality from Untrusted Control Sphere	CVE-2026-111357 record and NVD	[4] [7]
CWE-306	Missing Authentication for Critical Functionality	CVE-2026-111357 KEV entry	[9]
CWE-862	Missing Authorization	CVE-2026-111357 KEV entry	[9]
CWE-345	Insufficient Verification of Data Authenticity	CVE-2026-111357 KEV entry	[9]
CWE-340	Generation of Predictable Numbers or Identifiers	CVE-2026-118527 record, NVD and KEV	[5] [8] [9]

CAPEC entries that the CNA records assign, and those the library relates to these CWEs or techniques that meet the record [3] [5] [24]:

CAPEC	Name	Via	Where it meets the record
CAPEC-115	Authentication Bypass	CVE-2026-104935 record	Assigned by the CNA on the record for the authentication bypass [3] (**Confirmed**)
CAPEC-17	Using Malicious Files	CVE-2026-118527 record	Assigned by the CNA on the record for the predictable-filename upload [5] (**Confirmed**)

CAPEC	Name	Via	Where it meets the record
CAPEC-22	Exploiting Trust in Client	CWE-290	A request-routing bypass, with Volexity's header/path mismatch detection [12] (**Inferred**)
CAPEC-565	Password Spraying	T1110.003	Spraying against directory accounts [12]
CAPEC-158	Sniffing Network Traffic	T1040	The renamed packet-capture tool [12]
CAPEC-268	Audit Log Manipulation	T1070	Debug and audit log tampering [12]

The library relates no CAPEC to CWE-340 [24] (**Demonstrated**), but the CNA assigns CAPEC-17 on the CVE-2026-118527 record [5] (**Confirmed**). The race condition Volexity describes has no CWE in any record, so no race-condition CAPEC is bound [8] [24] (**Demonstrated**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Session Volume Analysis	T1190	Volexity's welcome.cgi request-volume monitoring [12]
Application Protocol Command Analysis	T1190, T1071.001, T1041, T1110.003	Request-path and routing-header mismatch detection [12]
Process Code Segment Verification	T1068	The in-memory code changes only memory forensics found [12] (**Inferred** fit)
Credential Rotation, with Credential Revocation and Reissue Credential	T1552, T1110.003	CISA's reset of all passwords, revocation and reissue of certificates, and API key reset [10]
Credential Compromise Scope Analysis	T1552, T1110.003	Scoping which LDAP, LAPS and BitLocker secrets were read [12] (**Inferred**)

CISA's factory reset and configuration restore correspond to Restore Software and Restore Configuration, which the library does not relate to these techniques [10] [24] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/ivanti-connect-secure-2026.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`. A score of 75 means a CVE record or government advisory describes the behavior; 50 means Volexity's report describes it; 25 means a capability, an assessment or a close-but-inexact fit rather than an observed act (T1587.004, T1588.007, T1601.001). Each comment names the event and the source numbers.

Cross-cutting themes

- **Edge appliances keep failing the same way.** Seventeen Connect Secure and Pulse Connect Secure KEV entries since November 2021 [9] say the VPN edge is a standing exposure, not an incident (**Inferred**). See Threat Actors: China for the 2024 and 2025 rounds.
- **Patch first, fix second.** Ivanti shipped the bypass fix it had, then the escalation fix 16 days later [12] [23]. The trade-off is defensible, but it leaves a window that version-based tools hide (**Inferred**).
- **Integrity checks are not forensics.** The vendor tool gave a false clean [10] [12] (**Confirmed**); recovery means a factory reset and full credential rotation, not a passing check (**Inferred**).
- **The record is a moving target.** Two CNAs, three CWE sets, two scores and a KEV entry that predates its CVE record's publication [4] [5] [7] [9] [23]. Programs that key on one feed will see a different chain (**Inferred**).
- **One assessment, not a trend.** Volexity's medium-confidence LLM finding [12] is a single data point; whether AI lowers the cost of zero-days is not established by this record (**Inferred**). See AI Threats in the Cybersecurity Industry.

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Ivanti, October 2026 Security Update, 13 Oct 2026 14:33 UTC	ivanti.com/blog/october-2026-security-update	2026-11-11	Confirmed
2	Ivanti, November 2026 Security Update, 10 Nov 2026	ivanti.com/blog/november-2026-security-update	2026-11-11	Confirmed
3	CVE Program record CVE-2026-104935 (CNA Ivanti)	cveawg.mitre.org/api/cve/CVE-2026-104935	2026-11-11	Confirmed
4	CVE Program record CVE-2026-111357 (CNA MITRE)	cveawg.mitre.org/api/cve/CVE-2026-111357	2026-11-11	Confirmed
5	CVE Program record CVE-2026-118527 (CNA Ivanti)	cveawg.mitre.org/api/cve/CVE-2026-118527	2026-11-11	Confirmed
6	NVD, CVE-2026-104935	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-104935	2026-11-11	Confirmed
7	NVD, CVE-2026-111357	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-111357	2026-11-11	Confirmed
8	NVD, CVE-2026-118527	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-118527	2026-11-11	Confirmed
9	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
10	CISA, CISA Urges Patching Newly Exploited Vulnerabilities in Ivanti Connect Secure, 13 Oct 2026, revised 30 Oct 2026 (the singular-slug URL serves the same alert)	cisa.gov/news-events/alerts/2026/10/13/...	2026-11-11	Confirmed
11	CISA, BOD 26-04, Prioritizing Security Updates Based on Risk, 10 Jun 2026	cisa.gov/news-events/directives/bod-26-04-...	2026-11-11	Confirmed
12	Volexity, A Series of Unauthenticated Events: Chained Exploitation of Ivanti Connect Secure Zero-Days, 13 Oct 2026, with an undated update note recording Ivanti's 29 Oct 2026 patch	volexity.com/blog/2026/10/13/...	2026-11-11	Confirmed
13	Volexity, threat-intel repository, 2026-10-13 Ivanti (IOCs and YARA)	github.com/volexity/threat-intel/.../2026-10-13 Ivanti	2026-11-11	Confirmed
14	Canadian Centre for Cyber Security, Ivanti security advisory AV26-1035, 13 Oct 2026, Update 2 30 Oct 2026	cyber.gc.ca/en/alerts-advisories/ivanti-security-advisory-av26-1035	2026-11-11	Confirmed
15	INCIBE-CERT, INCIBE-2026-737, Multiple vulnerabilities in Ivanti products, 14 Oct 2026, updated 3 Nov 2026	incibe.es/incibe-cert/alerta-temprana/avisos/...	2026-11-11	Confirmed
16	HKCERT, Ivanti Connect Secure Multiple Vulnerabilities, 2 Nov 2026	hkcert.org/security-bulletin/...	2026-11-11	Confirmed
17	Cyber Security Agency of Singapore, AL-2026-147, 20 Oct 2026	csa.gov.sg/alerts-and-advisories/alerts/al-2026-147/	2026-11-11	Confirmed
18	Rapid7, ETR: Ivanti Connect Secure zero-day exploited in the wild (CVE-2026-104935), 13 Oct 2026	rapid7.com/blog/post/etr-ivanti-connect-secure-...	2026-11-11	Reported
19	BleepingComputer, report on Ivanti's Connect Secure zero-day warning, 13 Oct 2026	bleepingcomputer.com/news/security/ivanti-warns-of-...	2026-11-11	Reported
20	BleepingComputer, report on Ivanti patching two more chained zero-days, 2 Nov 2026	bleepingcomputer.com/news/security/ivanti-patches-two-more-...	2026-11-11	Reported
21	Cybersecurity Dive, report on chained Ivanti Connect Secure exploitation, 14 Oct 2026	cybersecuritydive.com/news/hacker-ivanti-connect-secure-chained-exploitation/832983/	2026-11-11	Reported
22	The Stack, report on Ivanti's 29 Oct patches, 29 Oct 2026	thestack.technology/ivanti-patches-two-more-cves-...	2026-11-11	Reported
23	The Hacker News, report on attackers chaining three Ivanti Connect Secure flaws, 31 Oct 2026	thehackernews.com/2026/10/attackers-chain-three-ivanti-connect.html	2026-11-11	Reported
24	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `campaigns.jsonl`, `groups.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` page tree including C0029	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
25	TeamStarWolf, Threat Actors: China	/case-studies/THREAT_ACTORS_CHINA.md	2026-11-11	Confirmed

Not opened, so not cited as sources: Ivanti's security advisory on its support hub (rendered only an error shell), CIS advisory 2026-115 (HTTP 404), Dark Reading's coverage (HTTP 403; its account of how Ivanti found the flaw is not checked), and the Defused and Shadowserver primaries behind the press figures.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors: China, AI Threats in the Cybersecurity Industry, PHP2Shell and October 2026, The Year 2026 in Intrusions, Timeline
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, AI Security Reference
- Vulnerability Management Reference, Vulnerability Prioritization Reference
- Campaigns: C0029 Cutting Edge
- Techniques: T1587.004 Exploits, T1588.007 Artificial Intelligence, T1190 Exploit Public-Facing Application, T1068 Exploitation for Privilege Escalation, T1601.001 Patch System Image, T1070 Indicator Removal, T1685.006 Clear Linux or Mac System Logs, T1036.003 Rename Legitimate Utilities, T1552 Unsecured Credentials, T1040 Network Sniffing, T1110.003 Password Spraying, T1654 Log Enumeration, T1071.001 Web Protocols, T1041 Exfiltration Over C2 Channel, T1059.004 Unix Shell, T1059.006 Python, T1140 Deobfuscate/Decode Files or Information, T1070.004 File Deletion, T1564.001 Hidden Files and Directories, T1087.002 Domain Account, T1016 System Network Configuration Discovery, T1005 Data from Local System
- CAPEC: CAPEC-115, CAPEC-17, CAPEC-22, CAPEC-565, CAPEC-158, CAPEC-268
- Navigator layers, including this study's layer, ivanti-connect-secure-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies